TILBUD · OFFENTLIG ANSKAFFELSE

SAK 2026-105336

Bilag 2 Vedlegg A — Sikkerhet, styring og ROS

SSA-T

LEVERANDØR

Asbjørn Rørvik
Enkeltpersonforetak · org.nr 820 252 632
Vipeveien 7B, 4323 Sandnes
hei@asbjornrorvik.dev

OPPDRAGSGIVER

Oslo kommune
Velferdsetaten · RUSinfo

TILBUDSFRIST

05.05.2026

DATO

24. april 2026

Bilag 2 — Vedlegg A: Sikkerhet, styring og ROS

Anskaffelse: Selvhjelpsapp for kokainbrukere (RUSinfo) — saksnr. 2026-105336 **Leverandør:** Asbjørn Rørvik (org.nr. 820 252 632) **Dato:** 24.04.2026

Dette vedlegget utdyper Leverandørens svar på Bilag 1 kap. 4.4 (sikkerhet, styring, drift). Løsningen behandler **ingen personopplysninger**, og flere krav i 4.4 er dermed ikke fullt utløst. Vedlegget dokumenterer likevel de tiltakene som gjelder for kode, drift, backup og risiko — slik at oppdragsgiver får innsyn i leverandørens sikkerhetsmodenhet.

---

1. Omfang og prinsipper

Løsningen består av:

- **Mobilapp** (React Native, iOS + Android) — all brukerdata lagres kun lokalt på enheten (AsyncStorage / Keychain / Keystore). Ingen innlogging, ingen synkronisering, ingen analytics, ingen tredjepartssporing.
- **Backend (Strapi, headless CMS)** — kun redaksjonelt innhold (moduler, tekst, bilder). Ingen brukerdata. Publiseringsflyt for RUSinfo-redaksjonen.
- **Kildekode** — ligger i kundens Git-repo fra dag 1. Leverandøren har kun push-tilgang i kontraktsperioden.

Styrende prinsipper:

- **Minimering** — ingen data som ikke trengs, samles inn.
- **Personvern ved utforming (GDPR art. 25)** — arkitekturen gjør lagring av personopplysninger umulig i frontend; backend eksponerer kun publiserte innholdsressurser.
- **Åpen og etterprøvbar kode** — kundeeid repo, ADR-logg, åpne tredjepartslisenser (se Bilag 10).
- **Kontinuitet** — all kunnskap i repo (SETUP.md, CONTRIBUTING.md, ARCHITECTURE.md, ADR-er) slik at en annen React Native-utvikler kan overta uten kunnskapstap.

---

2. Styringssystem for informasjonssikkerhet

Leverandøren driver ikke et sertifisert ISMS (ISO 27001), men anvender kontroller basert på ISO 27001 Annex A og NSMs grunnprinsipper for IKT-sikkerhet 2.0:

Område	Tiltak
Tilgangsstyring	MFA på alle utvikler-kontoer (GitHub, Apple Developer, Google Play, Strapi-hosting). Unike passord i passordmanager (1Password). Ingen delte kontoer.
Kode- og avhengighetssikkerhet	Dependabot/Renovate på repo. CI kjører `npm audit` + lint + typecheck ved hver PR. Signerte commits. Hemmeligheter aldri i repo — kun i CI-secrets og lokal `.env` (gitignored).
Endringshåndtering	Alle endringer via PR med minst én review-syklus (kunden eller peer). ADR-logg for arkitekturvalg.
Logging	Strapi-tilgangslogger (admin-handlinger) aktivert. App-siden logger ikke brukeratferd.
Hendelseshåndtering	Varslingsrutine beskrevet i punkt 5.
Opplæring	Leverandøren (solo) holder seg oppdatert på OWASP Mobile Top 10 og OWASP ASVS gjennom årlige gjennomganger.

3. Backup og gjenoppretting

Komponent	Backup-strategi	RPO	RTO
Kildekode (Git)	Primært i kundens GitHub/GitLab. Mirror hos Leverandøren.	0	< 1 t
Strapi-innhold (DB)	Daglig automatisk dump til objektlager (kryptert). 30 dagers rullerende retensjon. Månedlig arkivdump i 12 mnd.	24 t	4 t
Strapi-mediefiler	Daglig synk til objektlager.	24 t	4 t
CI/CD-hemmeligheter	Eksport + kryptert kopi i 1Password-tresor eid av kunden.	Ved endring	< 1 t
Appstore-signeringsnøkler	Apple/Google forvalter primært. Kopier av Android upload-nøkkel og iOS-provisioning lagres kryptert i kundens passordtresor.	Ved endring	< 4 t

Gjenopprettingsrutinen er dokumentert i `DISASTER-RECOVERY.md` i repo, og testes ved overlevering (M6) samt minimum én gang årlig i vedlikeholdsperioden.

4. ROS-analyse (skisse)

Analysen er grovmasket og vil utvides ved oppstart sammen med oppdragsgiver. Skala: Sannsynlighet (S) og Konsekvens (K) fra 1 (lav) til 4 (høy). Risiko = S × K.

#	Hendelse	S	K	R	Tiltak
R1	Skadelig kode via tredjepartsavhengighet (supply chain)	2	3	6	Låst versjon i `package-lock`, Dependabot, månedlig review av CVE-er.
R2	Uautorisert tilgang til Strapi-admin	2	3	6	MFA, IP-begrensning på admin-panel, separate redaktør-roller, tilgangslogg.
R3	Lekkasje av signeringsnøkler (Android upload / iOS certs)	1	4	4	Nøkler i kryptert tresor hos kunden, roteres ved mistanke, 2-manns-prosess dokumentert.
R4	Datatap i Strapi (feilslettet innhold)	2	2	4	Daglig backup (se pkt. 3), soft-delete i Strapi, innholdshistorikk.
R5	Leverandør uavailable (sykdom, bortfall) — solo-leverandør	2	3	6	All kunnskap i repo, kunden eier kode og nøkler, onboarding-dokumentasjon gjør at en annen RN-utvikler kan overta på 1–2 dager. 24/48-t responstid gjelder kun når leverandøren er tilgjengelig; fravær varsles og alternativ kontakt anbefales.
R6	Denial of service mot Strapi	2	2	4	CDN foran API (cache av publisert innhold), rate-limiting på admin. App fungerer offline på allerede hentet innhold.
R7	Sårbarhet i mobilrammeverk (React Native / native)	2	3	6	Følger LTS-versjoner, patcher minst hvert kvartal, kritiske sikkerhetsoppdateringer innen 30 dager.
R8	Butikk-avvisning (App Store / Play) ved publisering	2	3	6	Early submission for review i uke 12, retningslinjer for sensitive helseemner gjennomgått på forhånd.
R9	Tilgjengelighets-regresjon (WCAG 2.1 AA)	2	3	6	Automatiske UU-tester i CI, manuell VoiceOver/TalkBack-test før hver release.
R10	Kunden mister tilgang til kode/nøkler ved kontraktsslutt	1	4	4	Kode og nøkler er allerede hos kunden; leverandørens tilganger kan tilbakekalles uten tap.

Risikoregister vedlikeholdes som `RISK-REGISTER.md` i repo og gjennomgås ved hver milepæl (M0–M6) samt årlig i vedlikeholdsperioden.

5. Hendelseshåndtering og varsling

Hendelsestype	Responstid	Kanal	Eskalering
Kritisk sikkerhetshendelse (mulig kompromittering)	Umiddelbar, senest 4 t	E-post + telefon til oppdragsgivers kontaktperson	Oppdragsgiver varsler NSM/Datatilsynet ved behov (selv om personopplysninger ikke er involvert).
Alvorlig nedetid (> 1 t)	4 t	E-post	Daglig statusrapport til kontaktperson til hendelsen er lukket.
Øvrige feil	24/48 t jf. Bilag 7	Sakssystem / e-post	—

Enhver hendelse loggføres i `INCIDENT-LOG.md` med tidslinje, rotårsak og læringstiltak.

6. Oppsummering

Løsningen er bygget slik at de største personvern- og sikkerhetsrisikoene i et helserelatert produkt **designes bort** (ingen persondata, ingen innlogging, ingen sporing). Det som gjenstår — kodekvalitet, tilgangsstyring, backup av redaksjonelt innhold, og kontinuitet rundt en solo-leverandør — er håndtert gjennom kontrollene beskrevet over.

Oppdragsgiver kan når som helst be om gjennomgang av ADR-logg, risikoregister, backup-status og hendelseslogg, enten skriftlig eller i styringsmøte.